Signed but Steerable: Measuring and Closing the Text–Vector Integrity Gap in Offline Retrieval-Augmented Generation

Georgios Feretzakis and Alexandros Papaspyridis

securagen.ai, Athens, Greece
research@securagen.ai

arXiv:2611.06498v1 [cs.CR] 4 Nov 2026

Abstract

Offline retrieval-augmented generation (RAG) on edge devices is updated through signed knowledge packs that carry text and precomputed embedding vectors. A signature proves who published a pack, not that its vectors encode its text. We study this text–vector integrity gap. A verifier that recomputes vectors and accepts them within a cosine tolerance concedes a predictable share of queries to an attacker who controls the vectors: the hijack rate equals the distribution of angular retrieval margins at the tolerance (the margin law). Margins are small in five corpora and two embedding models, so an idealised tolerance at the level of floating-point noise leaves up to 5.5% of queries exposed (at most 1.2% in any corpus once exact duplicate documents are excluded), and a threshold calibrated from our CPU INT8–FP32 comparison of a small embedding model (at the empirical 0.1% quantile of honest cosines) leaves 98–100% exposed; on a Raspberry Pi 5 running a local language model, such an attack lowers correct answers from 0.75 to 0.39. Integrity audits of compressed vector stores fare no better: on a FAISS product-quantisation index over 57,638 documents, tampered vectors that all pass the audit put the attacker's document first for 25% of targets. Verifying quantisation codes instead, with ambiguity decided by the verifier, a calibrated guard band and canonicalisation, accepted every honest vector in our samples on three platforms and left the publisher no choice. We also show that common floating-point and dynamic-INT8 inference pipelines are not bit-reproducible across batch sizes or architectures, and report pre-registered negative results on abstention, context pruning and semantic screening. We release code and data.

Keywords: retrieval-augmented generation, embedding integrity, vector databases, product quantisation, determinism, edge AI, supply-chain security

1 Introduction

Retrieval-augmented generation (RAG) lets a language model answer from a local corpus [2], and small quantised models now make fully offline RAG feasible on embedded boards [1, 13]. In disconnected deployments, such as field, industrial and defence settings, knowledge reaches the device through update packages. Our earlier work proposed signed, versioned *knowledge packs* for this purpose and evaluated them on a Raspberry Pi 5 [16]. It also left an open problem: a validly signed but poisoned pack passed every pack check.

This paper studies a sharper version of that problem. A knowledge pack typically ships text together with precomputed embedding vectors, because computing embeddings on a small device is slow; in our earlier study, embedding a 950-passage pack on the Pi's CPU took about 29 minutes [16]. The signature then covers the vectors, but nothing guarantees that the vectors encode the text. An attacker who controls the publishing pipeline, or an insider, can ship benign text with vectors chosen to steer retrieval. The same gap exists in any vector database: what is stored is a vector, often compressed, and audits compare stored vectors with recomputed ones under some tolerance. Embedding weaknesses are recognised as a top risk for LLM applications [17], and per-embedding signatures have been proposed as a defence [18]. We ask what such checks actually guarantee, and how to make them sound.

We address four research questions with experiments on a Raspberry Pi 5 running a local Qwen2.5-3B model, a desktop for scale, and an Apple M2 laptop as a third platform:

- **RQ1.** If a verifier accepts shipped vectors within a cosine tolerance of recomputed ones, how many queries can an attacker hijack, and can this be predicted without running attacks?
- **RQ2.** How exposed are the compressed storage formats of vector databases to the same attack?
- **RQ3.** Can exact verification close the gap across heterogeneous hardware, and what does it require?
- **RQ4.** What does verification cost on the CPU of an edge device that also runs the language model, and what happens end to end?

Our contributions are:

1. **The margin law** (Sect. 3): for an optimal attacker, the hijack rate under tolerance τ equals the empirical distribution of angular retrieval margins at $\arccos \tau$. It matches attack simulation exactly and lets an operator measure exposure without attacking. On all answerable SQuAD 2.0 questions and four BEIR test sets (five corpora) with two embedding models, margins are small, so even float-noise tolerances leave measurable exposure, and a threshold calibrated from our CPU INT8–FP32 comparison leaves 98–100% of queries exposed (Sect. 5.1).
2. **Exposure of compressed vector stores** (Sect. 5.2): tolerance-based audits against SQ8, SQ4, PQ and binary storage leave 2–15%, 55–89%, about 100% and 100% of queries exposed. On real FAISS indexes, an executed attack on product quantisation passes the tolerance check for every tampered vector and puts the attacker's document first for 25% of targets; code-level verification blocks all of them.
3. **Exact code-level verification** (Sect. 5.3): comparing quantisation codes, with ambiguity decided only by the verifier, a guard band calibrated to measured float noise and a verify-and-canonicalise rule, accepted every honest vector in our samples on three platforms and four compute backends, without special hardware. We also show that floating-point and dynamic-INT8 pipelines are not bit-reproducible across batch sizes or architectures.
4. **Measured on-device cost and end-to-end impact** (Sects. 5.4 and 5.5): verification on the device's CPU costs the concurrently running LLM 23–31% of its decoding speed, the attack lowers the device's correct answers from 0.75 to 0.39 under the INT8 reference threshold, and layered pack verification rejects all twelve structural update attacks we tested.
5. **Pre-registered negative results** (Sect. 5.6) on abstention, context pruning and semantic screening, and an open release of code, data and the protocol with its deviation log.

2 Background, Threat Model and Related Work

2.1 Retrieval-Augmented Generation on Edge Devices

A retrieval-augmented generation pipeline splits a corpus into chunks, maps every chunk to a dense vector with an embedding model, and stores the vectors in an index. At query time the query is embedded with the same model, the nearest chunks by cosine similarity (or inner product of normalised vectors) are retrieved, optionally reranked by a cross-encoder, and placed in the prompt of a language model [2]. The quality and the safety of the answer therefore depend on which chunks the index returns, and that decision is taken entirely in vector space.

On edge devices the same pipeline runs without a network connection, with a small quantised language model [1, 13] and memory- and latency-aware indexing [3]. Knowledge reaches such a device through update packages. Embedding a corpus on a small board is slow, about 29 minutes for a 950-passage pack on the CPU of a Raspberry Pi 5 in our earlier study [16], so packs commonly ship precomputed vectors with the text. The device then has to decide whether to trust them.

2.2 Vector Storage and Approximate Search

Vector databases rarely store full-precision vectors. To reduce memory and speed up search they store compressed codes: half-precision floats; scalar quantisation, which maps each dimension to one of 2^b levels between per-dimension bounds (SQ8, SQ4); product quantisation, which splits a vector into sub-vectors and stores, for each, the index of the nearest centroid in a learned codebook [28]; anisotropic and other learned quantisers [44]; or binary codes that keep only the sign of each dimension. These codes are combined with coarse partitioning or proximity graphs [7] and are implemented in widely used libraries [29, 45]. Every compressed format reconstructs a vector only approximately. The reconstruction error is small for half-precision floats, a fraction of a degree for SQ8, and tens of degrees for product and binary codes, as we measure in Sect. 5.2. Any audit that compares stored vectors with recomputed ones must tolerate this error.

2.3 Knowledge Packs and Their Integrity

A knowledge pack [16] contains text chunks, a manifest with operations (add, supersede, delete), optional precomputed vectors, and signatures. Role separation in the spirit of TUF [11] lets a content key add chunks while changes to existing chunks require a threshold of editor signatures; a transparency log in the spirit of Certificate Transparency [30] and monotonic version state protect against rollback and against conflicting extensions of a device's retained history; manifests follow the IETF information model for IoT firmware updates [12]. These mechanisms descend from software supply-chain security, where signatures, attestations and transparency logs establish who produced an artefact and how [31, 46], and from recent specifications for signing machine-learning models [10]. They bind bytes to keys and to a history. They do not bind a vector to the text it is supposed to encode: a valid signature over a pack whose vectors were chosen to steer retrieval is still a valid signature.

2.4 Floating-Point and Quantised Numerics

Recomputing a vector does not, in general, reproduce it bit for bit. Floating-point addition is not associative [42], so the result of a reduction depends on its order, and the order depends on kernels, batch sizes, padding, thread counts and hardware. Large-language-model serving has recently been shown to be nondeterministic for exactly this reason, because kernels are not invariant to batch composition [19]. Quantisation adds a second, larger source of deviation [43]. Static quantisation fixes scales offline from calibration data; dynamic quantisation computes them at run time from the inputs, so that, with per-tensor scales, one input can change the computation applied to another in the same batch [20]. Integer-only inference [24, 25] avoids floating-point reductions altogether and can be made bit-identical across devices [22, 23].

Accelerators such as neural processing units execute quantised graphs produced by a vendor compiler; how far their outputs deviate from floating point, and whether they are bit-reproducible, can depend on the compiled graph and the toolchain. We measure these properties for floating-point and INT8 pipelines on general-purpose hardware (Sect. 5.3) and leave dedicated accelerators to future work.

2.5 Threat Model

System. A publisher distributes a pack $P = \{(t_i, v_i)\}$ of text chunks t_i and vectors v_i, signed under the pack's key hierarchy. A verifier, either the edge device itself or an auditor of a vector store, can compute $f(t_i)$, the embedding of t_i under the agreed model and configuration. For a vector store, v_i is replaced by stored codes c_i under a codebook.

Adversary. The adversary can make the verifier receive a pack or a store whose signatures are valid: a compromised publisher or build pipeline, a malicious insider who holds a content key, or a compromised writer of a vector store. Every text chunk the adversary ships passes content review, and the adversary chooses the vectors v_i or the codes c_i. Besides tampering with the vectors of existing chunks, the adversary may add chunks whose text passes review, as a holder of a content key can; in the end-to-end experiment it adds one such chunk, an editorial note whose honest vector would not bring it into the context. The adversary knows

the embedding model, which is public, and in the worst case the target queries; we also evaluate an adversary who knows only other questions about the target passage.

Goals. Hijacking places a chosen chunk at rank 1 for a target query instead of the gold chunk. *Payload delivery* places a chosen chunk, for example one containing an instruction to the language model, in the top-k context.

Verifiers. We consider five verifier designs. (V0) No verification. (V1) Signature verification only. (V2) Recomputation with tolerance: accept v_i if $\cos(v_i, f(t_i)) \geq \tau$. (V3) Exact equality with a canonical computation: accept v_i only if $v_i = f_c(t_i)$ bit for bit, where f_c is a computation demonstrated to be bit-reproducible at publisher and verifier. (V4) Code-level verification for compressed stores: accept the stored codes only if each entry equals the verifier's own code of $f(t_i)$, or equals its neighbouring code at an entry the verifier itself marks as ambiguous, and then replace the stored codes with the verifier's codes (Sect. 5.3).

Assumptions and scope. The verifier's embedding model, configuration, code and trust anchors are not under the adversary's control, and the codebook is obtained from a trusted source. We do not consider attacks that modify the model weights, the text of the chunks [8, 38], the index structure beyond the stored vectors or codes, or the query channel [39]; nor side channels or denial of service.

2.6 Related Work

Poisoning and manipulation of retrieval. Adversarial passages inserted into a corpus can be retrieved for many queries [38], and crafted texts can make a RAG system produce attacker-chosen answers [8]. Indirect prompt injection places instructions in content that an LLM-integrated application retrieves [39]. Certifiably robust aggregation bounds the influence of a small number of corrupted passages [9]. These attacks change the *text* that enters the corpus, and defences inspect or aggregate text. Our attack manipulates the vectors associated with fixed, review-admitted text, rather than optimising the text to change its embedding; content review and text-level defences do not see this manipulation. OWASP lists vector and embedding weaknesses among the top risks for LLM applications, including poisoning by insiders or unverified data providers, and recommends regularly auditing and validating the integrity of the knowledge base [17]; it does not prescribe how stored vectors are to be bound to their text.

Attacks on and through embeddings. Embeddings leak information about their inputs [40], and text can be largely reconstructed from them [41]. Closest to our setting, VectorSmuggle shows that an attacker with write access to an ingestion pipeline can hide data in embeddings with small perturbations that preserve retrieval, and proposes VectorPin, which signs each embedding together with its source content and producing model so that any later modification is detected [18]. Provenance of this kind detects tampering *after* signing. Our adversary is the signer, or a writer whose output is signed, and the question is whether the signed vectors are consistent with the text; we quantify what tolerance-based consistency checks concede and give checks that concede nothing under stated assumptions (a bit-reproducible computation, or a trusted codebook with canonicalisation).

Integrity and provenance in software and model supply chains. Update frameworks, transparency logs and signing infrastructures protect the distribution of artefacts against key compromise, rollback and tampering [11, 30, 31, 46], and model-signing specifications extend these guarantees to machine-learning models [10]. They authenticate bytes and their history, not the semantic consistency between two parts of an artefact. Knowledge packs [16] inherit these protections and, as we show, need an additional binding between text and vectors.

Determinism, reproducibility and verifiable inference. Floating-point non-associativity [42] and the lack of batch invariance [19] make inference results depend on how a request is executed; dynamic quantisation can even couple co-batched requests [20]. Verifiable-inference systems handle this in two ways. Tolerance-based schemes accept results that are close to a recomputation, using locality-sensitive commitments to intermediate activations [26]. Exact schemes remove nondeterminism, either with pinned kernels and drivers on a fixed GPU architecture [21] or with integer-only arithmetic that gives identical bits across different devices [22, 23], building on integer-only quantisation [24, 25]. Quantisation can also be abused to hide malicious model behaviour that appears only after deployment [27]. Our work transfers the tolerance-versus-exactness question from generated text to retrieval: the margin law quantifies exactly what a tolerance concedes in vector search, and code-level verification shows that coarse quantisation cells make exact checks portable across

Table 1 Positioning of this work relative to the closest lines of research

Line of work	Representative	What it protects or shows	What it leaves open for our setting
Retrieval poisoning	[38, 8, 9]	Attacks and defences for malicious *text* in the corpus	Benign text with malicious vectors
Embedding provenance	[18]	Detects modification of a vector after it was signed	A compromised signer or writer
Supply-chain signing	[11, 30, 31, 46, 10]	Authenticity and history of artefacts	Consistency between text and vectors inside an artefact
Tolerance-based verifiable inference	[26]	Detects deviating LLM computations under float noise	What a tolerance concedes when outputs are retrieval vectors
Exact verifiable inference	[21, 22, 23]	Bit-identical results by pinning or integer arithmetic	Compressed stores and retrieval vectors
Vector quantisation	[28, 44, 29, 45]	Memory- and speed-efficient search	Integrity audits under quantisation error
This work	–	Margin law for tolerance checks; exposure of compressed stores; code-level verification; on-device cost and impact	Edge accelerators; IVF and graph indexes; text-and-vector attackers

floating-point platforms. We also measure the reproducibility of common floating-point and INT8 pipelines.

Vector search and quantisation. Product quantisation [28], anisotropic quantisation [44], proximity graphs [7] and GPU-scale libraries [29, 45] are optimised for recall, memory and speed. VectorSmuggle also examines writer-side manipulation of quantised embeddings, with a different goal [18]; to our knowledge, the retrieval-hijacking exposure of compressed vector stores under recomputation-based integrity audits, and its removal by verifier-controlled canonicalisation, have not been quantified.

Edge RAG, abstention and update screening. Edge RAG systems reduce memory and latency on constrained devices [3]. Selective answering under domain shift [4] and unanswerability in RAG [5] have been studied on server hardware, building on datasets with unanswerable questions [14]. Natural language inference has been proposed to verify answers [15], but NLI models are known to rely on lexical overlap [37], which matters for screening edits that change a single fact. Our earlier study measured trust mechanisms on a CPU-only Raspberry Pi 5 [16]; this paper adds the text–vector binding and vector databases.

Table 1 summarises how this work relates to the closest lines of research.

3 The Margin Law

Let q be a normalised query vector, g the gold unit (passage or window) and C the set of other units, all normalised; when several units are relevant (positive BEIR qrels, or the windows of the gold SQuAD passage), g is the closest of them and C contains only non-relevant units. Let $\theta_g = \arccos(q \cdot g)$ and $\theta_c = \min_{c \in C} \arccos(q \cdot c)$, and consider queries where the gold unit ranks first, i.e. $\theta_g \leq \theta_c$. In the cross-corpus analysis (Fig. 1) a gold unit tied with a competitor counts as first; in Table 2, ties are broken by index order. Ties give zero margins, which are hijackable at any non-zero tolerance. Define the *angular margin* $m(q) = \theta_c - \theta_g$. A verifier of type V2 accepts a shipped vector $\tilde{v}$ for a chunk with honest vector v whenever $\angle(\tilde{v}, v) \leq \alpha$ with $\alpha = \arccos \tau$ (recomputation noise is discussed below). The optimal attacker rotates the closest non-gold vector towards q by α, which reduces its angle to q to $\max(\theta_c - \alpha, 0)$. For $\theta_g > 0$, rank 1 is hijacked if and only if $\max(\theta_c - \alpha, 0) < \theta_g$, that is $m(q) < \alpha$; if $\theta_g = 0$ (a query identical to its gold vector), no competitor can rank strictly above the gold unit, and the law is an upper bound. Over a query set Q,

$$\mathrm{HR}(\tau) = \frac{1}{|Q|} \sum_{q \in Q} \mathbf{1}\left[m(q) < \arccos \tau\right], \tag{1}$$

the fraction of margins strictly below $\arccos \tau$. An attacker who may also rotate the gold vector away by α obtains $m(q) < 2\alpha$; we report the conservative single-rotation case. Five remarks delimit what the law

measures. First, HR is *per-query exposure*: the share of queries for which some admissible tampering of one vector hijacks rank 1. We do not claim that one tampered index realises all per-query hijacks at once; the end-to-end experiment of Sect. 5.5 builds one tampered context per question. Second, it is conditional on queries whose gold unit ranks first under honest vectors, which is where hijacking is defined; on SQuAD this is 78% (BGE-M3) and 70% (MiniLM) of the answerable questions, and exposure over all questions scales by these factors. Third, at very small tolerances the exposed queries are those whose closest competitor is a near-duplicate of the gold unit; displacing the gold by such a competitor is not necessarily harmful, so small-tolerance exposure is an upper bound on harm, and harm is measured separately in Sect. 5.5. Fourth, we ignore recomputation noise. It is orders of magnitude smaller than all but the smallest tolerances we consider and shifts the accepted region by at most its own magnitude in either direction; exposure at a tolerance equal to the noise level (the FP32 rows of Table 2) is therefore an idealised figure. Fifth, the law asks whether some non-gold chunk can be made to outrank the gold unit, using the closest one; delivering a specific, fixed chunk is harder and is measured separately (Sect. 5.5). The law has two practical consequences. An operator can compute $\mathrm{HR}(\tau)$ from honest vectors and a query log, without attacking. And the safety of a tolerance depends on the corpus and the embedding model, not only on the tolerance. Numerically, recomputing all margins in double precision from normalised vectors with the stable formula $2\arcsin(\|q-d\|/2)$ changes no value by more than $4 \cdot 10^{-5}$ degrees and leaves every reported rate unchanged, for both the passage-level and the window-level units; margins that are exactly zero correspond to documents with identical text.

We also evaluate a *transfer* attacker that does not know the user's wording: it rotates the carrier towards the centroid of other questions about the same passage, and success is measured on the real question.

4 Experimental Setup

Hardware. Raspberry Pi 5 (16 GB, Arm Cortex-A76 CPU), on which the language model, the device-side embedding in ONNX Runtime and the pack verifier run on the CPU. A desktop (RTX 4090, 16 cores, WSL2) builds artefacts and runs scale experiments. An Apple MacBook Air (M2, 16 GB) is a third platform for the cross-device code-verification measurements.

Models. Qwen2.5-3B-Instruct (Q4_K_M) under llama.cpp [1, 13], with the commit, prompts and settings of our earlier study [16], whose scoring we also reuse (an answer is correct if it is not a refusal and contains the normalised gold answer; refusals are detected with the earlier study's abstention rule); BGE-M3 dense retrieval [6]; all-MiniLM-L6-v2 [32, 33] on 128-token windows, exported to ONNX and run in ONNX Runtime in FP32 and in dynamic INT8 (weights QInt8); ms-marco-MiniLM-L-6-v2 (cross-encoder), nli-MiniLM2-L6-H768 (natural language inference, NLI) and minilm-uncased-squad2 (extractive QA) [34]. Model revisions are pinned for all desktop and Raspberry Pi runs. The Apple M2 replication (Sect. 5.3) loaded the current revisions and recorded their hashes (all-MiniLM-L6-v2 `1110a243`, BGE-M3 `5617a9f6`); both equal the pinned revisions.

Data. The 950-passage SQuAD 2.0 corpus and 300 questions of [16] (100 answerable, 100 in-topic unanswerable, 100 out of corpus) [14]; for scale, all 4,690 answerable SQuAD 2.0 development questions on the corpus; four BEIR corpora (SciFact, NFCorpus, ArguAna, FiQA) [35]; and 1,000 MS MARCO v2.1 queries [36].

Protocol. Hypotheses, metrics and decision gates were written and dated before measurement and are released with the code; we call them pre-registered in this sense, as the protocol was not deposited in a public registry. Every deviation and exploratory analysis is logged with date and rationale (34 entries; the log released with the code omits the entries about experiments that are not reported in this paper). Reproducibility checks: the corpus is byte-identical to the earlier release, retrieval returns identical top-5 lists, and the earlier main configuration reproduces 60 of 60 answers exactly. Latencies are reported without llama-server prompt-cache hits, which we detect from the server's prompt timings.

Table 2 Margin law on SQuAD 2.0: share of queries an attacker can hijack (rank 1) under a verifier with cosine tolerance τ; BGE-M3 on passages (3,648 queries), MiniLM on 128-token windows (3,301 queries); 95% Wilson intervals are within ± 1.8 points. "Transfer": attacker who knows the target passage and other questions about it, but not the exact wording of the query

Tolerance τ	Angle	BGE-M3 law	BGE-M3 transfer	MiniLM law	MiniLM transfer
1 (exact)	0°	0.00%	0.00%	0.00%	0.00%
0.99999976 (FP32 x86 vs ARM)	0.04°	0.49%	0.05%	0.24%	0.03%
0.99999	0.26°	2.2%	0.5%	1.3%	0.15%
0.999	2.56°	24.6%	4.5%	16.8%	2.3%
0.99	8.11°	74.9%	21.7%	54.7%	10.2%
0.95	18.19°	99.6%	62.2%	91.9%	30.8%
0.904 (MiniLM CPU INT8 reference)	25.31°	100%	81.2%	98.4%	44.0%
0.8	36.87°	100%	91.6%	100%	58.5%

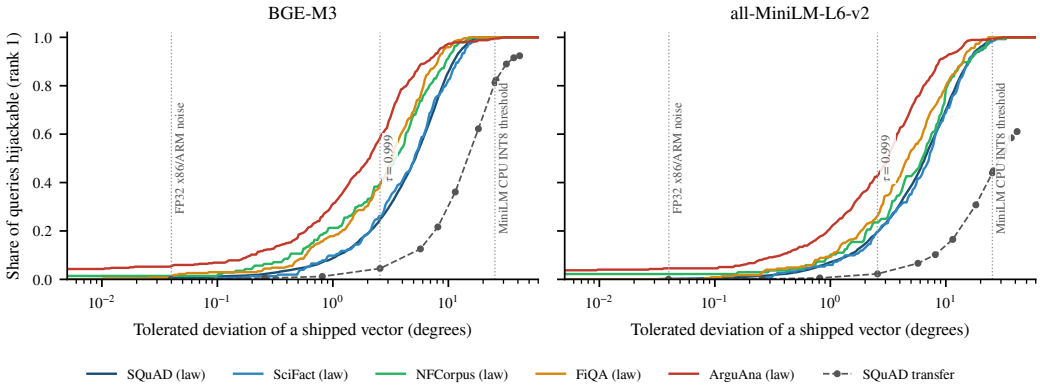

Figure 1 Hijack rate as a function of the tolerated deviation, for SQuAD and four BEIR corpora (margin law, passage-level retrieval for both models) and the transfer attacker on SQuAD. Vertical lines mark FP32 cross-architecture noise, $\tau = 0.999$ and the MiniLM CPU-INT8 reference threshold

5 Results

5.1 RQ1: Tolerance Is an Attack Budget

On the 300-question set, the margin-law prediction equals the simulated attack at every tolerance (maximum absolute difference 0.0). Table 2 reports the law on all answerable SQuAD questions whose gold unit ranks first: 3,648 with BGE-M3 on passages and 3,301 with MiniLM on 128-token windows, the unit the device embeds. BGE-M3 uses the passage index of the earlier study. Fig. 1 and the comparison with the BEIR corpora instead encode every corpus, SQuAD included, at passage level with inputs truncated at 512 tokens for BGE-M3 and 256 for MiniLM, giving 3,646 and 3,148 queries. The two BGE-M3 encodings agree to within a cosine of $1 - 10^{-8}$ for the 940 passages of at most 512 tokens and differ only for the 10 longer ones; the two-query difference comes from questions about one such passage. For MiniLM the unit differs (passages instead of windows), and the exposure at $\tau = 0.999$ is 19.7% instead of 16.8%. Median margins are 5.2° and 7.4°; 5% of queries have margins below 0.6° and 0.8°. A tolerance of 0.999 (2.6°) leaves 25% and 17% of queries hijackable. As an INT8 reference we use the 0.1% quantile (linear interpolation) of the cosines between dynamic-INT8 and FP32 outputs of all-MiniLM-L6-v2 in ONNX Runtime on the Raspberry Pi CPU over 1,745 windows, encoded with four threads in batches of 32 padded to the longest text in each batch (0.9040, 25.3°). Two of the 1,745 honest windows fall below it, the lowest at 0.898. Because dynamic quantisation depends on the batch, the threshold belongs to this configuration; re-encoding with the same settings reproduces the calibration vectors bit for bit, whereas batches of 64 change them by up to 0.03. It leaves 100% and 98.4% of queries hijackable, and 81.2% and 44.0% for an attacker who does not know the exact wording of the query. The threshold was calibrated for MiniLM; applying the same angular budget to BGE-M3 is a sensitivity analysis, not a measured BGE-M3 tolerance.

Table 3 Exposure of tolerance-based audits against compressed vector stores (5 corpora, 2 models; ranges over corpus–model pairs)

Storage	Bits/dim	Max. honest reconstruction angle	Hijackable queries
FP16	16	0.03°	0–5.2%
SQ8	8	0.35–0.56°	2.0–14.5%
SQ4	4	5.8–9.6°	55–89%
PQ ($d/8$ subvectors, 256 centroids)	1	23–40°	99.7–100%
Binary (sign)	1	41–47°	100%

Margins are small in every domain (Fig. 1). Median margins are 5.1–7.2° on SciFact, 3.5–6.3° on NFCorpus, 3.3–4.7° on FiQA and 2.1–3.2° on ArguAna, where 5% of queries are decided by less than 0.02° (BGE-M3). With FP32 cross-architecture noise as the tolerance, 0–5.5% of queries are exposed; with the MiniLM CPU-INT8 reference threshold, 98.7–100% in all five corpora. Most of the small-tolerance exposure in ArguAna and NFCorpus comes from exact duplicates. Of the 23 (BGE-M3) and 17 (MiniLM) ArguAna queries exposed at the FP32-noise tolerance, 18 and 14 have a margin of exactly zero, and in every one of these cases the competing document's text is identical to the gold document's after collapsing whitespace and lower-casing, while only one of the two documents is marked relevant in the qrels; the same holds for the 2 exposed NFCorpus queries with BGE-M3 and 2 of 3 with MiniLM. Displacing a document by its own copy is harmless. Removing these cases from the exposed count (the denominator is unchanged), exposure at the FP32-noise tolerance is 5/420 (1.2%) and 3/373 (0.8%) on ArguAna, 0/141 and 1/136 on NFCorpus, 18/3,646 (0.49%) and 7/3,148 (0.22%) on SQuAD, 2/269 (0.74%) and 0/225 on FiQA, and 0 on SciFact; these remaining cases are genuinely close, non-identical competitors. They are the non-zero intercepts of Fig. 1.

5.2 RQ2: Compressed Vector Stores

An audit that compares a recomputed embedding with a *stored* vector must tolerate the storage format's own reconstruction error. Setting the tolerance at the largest honest reconstruction angle (no false alarms on our data) and applying the margin law gives Table 3 and Fig. 2a. Half-precision storage has the lowest measured exposure; per-dimension 8-bit scalar quantisation leaves 2–15% of queries exposed; product quantisation and binary codes leave essentially all queries exposed.

Executed attack on a real vector database. We repeated the analysis with FAISS [29] indexes over all 57,638 BEIR FiQA documents (all-MiniLM-L6-v2 with inputs truncated at 128 tokens, so the number of queries whose gold document ranks first, 230, differs from the 225 of the cross-corpus analysis at 256 tokens; publisher vectors on GPU, verifier recomputation on CPU), with the tolerance set at each index's largest honest reconstruction angle (Table 4). We then executed the attack against the product-quantisation index: for 60 target queries drawn at random (fixed seed) from those whose gold document ranks first under the exact cosine ranking of the uncompressed vectors, the attacker replaces the codes of a carrier document (the highest-ranked non-relevant document at ranks 11–60 of that same exact ranking) with the codebook entries that most raise its score, reverting the lowest-gain changes until the decoded vector passes the verifier's global tolerance check. FAISS itself is not at fault: it provides storage formats and search, not integrity audits, and serves here as a realistic implementation of the formats that such audits must tolerate. All 60 tampered vectors pass the check, and under the index's own scoring, the inner product of the query with the decoded PQ vectors of all 57,638 documents (the ranking `IndexPQ` computes with the inner-product metric), the carrier ranks first for 25% of the targets (95% CI 16–37%). The margin-law columns of Table 4 measure something different: the exposure of an angular tolerance audit, computed from the cosine margins of the uncompressed vectors with the tolerance set to the largest angle between each index's decoded vectors and the uncompressed ones; they do not depend on the index's search metric (Hamming distance for `IndexBinaryFlat`), and we do not claim that they bound the executed attack, which optimises a different objective. The executed attack is an existence result: a tampered store that passes the audit puts the attacker's document at rank 1 under the index's own scoring for at least a quarter of the targets. Code-level verification with canonicalisation (Sect. 5.3) detects and removes all 60 tampered codes.

Table 4 Tolerance-based integrity checks on real FAISS indexes, BEIR FiQA (57,638 documents, 230 target queries with gold at rank 1). Tolerance: the largest angle between each index's decoded vectors and the uncompressed ones. Hijackable: margin law on the cosine margins of the uncompressed vectors, i.e. the exposure of the audit, independent of the index's search metric. The executed attack is scored with the index's own inner products of the query with the decoded PQ vectors

FAISS index	Tolerance (largest honest angle)	Hijackable queries, margin law [95% CI]
`IndexFlatIP` (float)	0.00°	0.0% [0.0, 1.6]
`IndexScalarQuantizer` (SQ8)	0.57°	8.3% [5.4, 12.5]
`IndexPQ` ($d/8\times8$ bits)	37.97°	100% [98.4, 100]
`IndexBinaryFlat`	44.64°	100% [98.4, 100]
Executed attack on `IndexPQ` (60 targets): 100% of tampered vectors pass the tolerance check; carrier ranks first 25% [16, 37]; blocked by code-level verification with canonicalisation 100% [94, 100]		

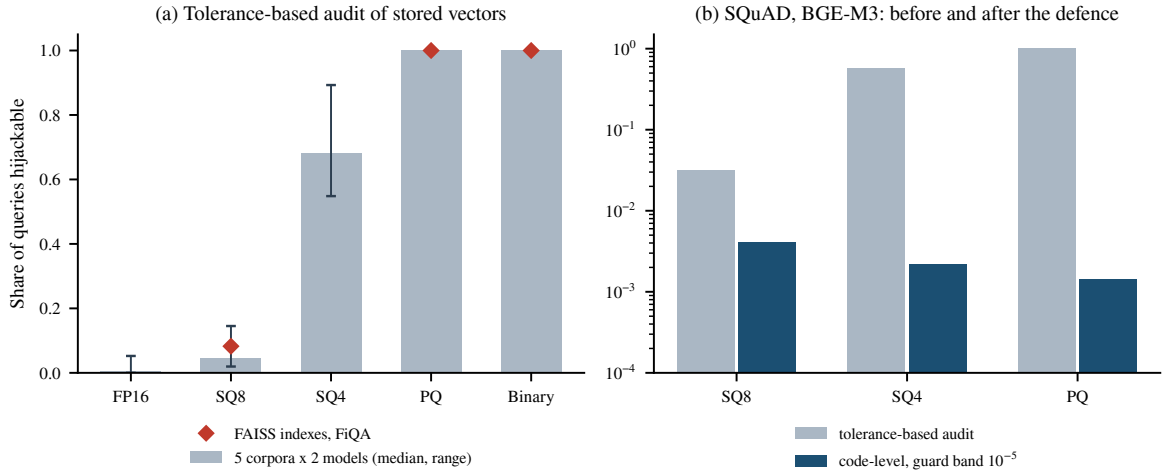

Figure 2 (a) Share of queries hijackable under a tolerance-based audit of stored vectors, per storage format (bars: median and range over five corpora and two models; diamonds: FAISS indexes over FiQA). (b) The same exposure on SQuAD with BGE-M3 before (tolerance-based audit) and after the defence (code-level verification with a deliberately wide 10^{-5} guard band and without canonicalisation; at the calibrated widths the residual is at most 0.16%, and canonicalisation removes it). Panel (b) shows the three formats covered by the residual analysis; FP16 stores no quantisation codes, and binary codes were not part of that analysis. Logarithmic scale

5.3 RQ3: Exact Verification

Determinism of inference pipelines. Exact verification by recomputation requires bit-reproducible inference. PyTorch FP32 on GPU and CPU changes with batch size (maximum absolute coordinate difference about 10^{-7}; FP16 on GPU 10^{-4}), and so does PyTorch on an Apple M2 CPU and Metal GPU ($1.4\cdot10^{-7}$ and $4.5\cdot10^{-8}$), although repeated runs are identical; ONNX Runtime FP32 is batch and padding invariant on one x86 machine but differs between x86 and ARM ($1.9\cdot10^{-7}$); ONNX Runtime dynamic INT8 changes by up to 0.03 depending on the other inputs in the batch, which is the expected behaviour of per-tensor dynamic quantisation [20].

Code-level verification. For compressed stores we propose to verify codes, not vectors. The verifier trusts only its own recomputation: it recomputes the embedding from the text, quantises it with the store's codebook and computes its own code c for every entry. It marks an entry *ambiguous* when, by its own recomputed value, honest float noise could have produced the neighbouring code a: for SQ when the value lies within $\varepsilon_{\mathrm{SQ}}$ of the rounding boundary (value units); for PQ when the squared distances to the nearest and second-nearest centroids differ by less than $\varepsilon_{\mathrm{PQ}}$ (squared-distance units, not comparable with $\varepsilon_{\mathrm{SQ}}$); for binary codes when $|v|<\varepsilon_{\mathrm{bin}}$. A stored vector is accepted only if every entry equals c, or is ambiguous and equals a; accepted vectors are then rewritten with the verifier's codes (canonicalisation). The publisher's float vectors are never used. We measured this verifier in both directions on three platforms (Table 5), scanning guard widths. Exact

Table 5 Code-level verification with the reference verifier (ambiguity decided by the verifier only; both directions). Each cell: share of honest vectors accepted with exact equality ($\varepsilon = 0$, range over the two directions) / smallest tested guard width that accepted all vectors (ε_{SQ}, ε_{bin} in value units; ε_{PQ} in squared-distance units). FiQA: MiniLM on 57,638 documents, BGE-M3 on a random sample (fixed seed) of 5,000; windows: 1,745 SQuAD windows, MiniLM in ONNX Runtime FP32 on x86 and on the Raspberry Pi's ARM CPU

	Desktop: NVIDIA GPU ↔ x86 CPU		**Apple M2: Metal GPU ↔ ARM CPU**		**x86 ↔ ARM (Pi)**
Scheme	**MiniLM**	**BGE-M3**	**MiniLM**	**BGE-M3**	**MiniLM windows**
SQ8	98.99–99.03% / $3 \cdot 10^{-7}$	91.3–91.5% / $3 \cdot 10^{-6}$	99.12–99.13% / $3 \cdot 10^{-7}$	91.0% / $3 \cdot 10^{-6}$	99.26–99.43% / 10^{-7}
SQ4	99.94% / 10^{-7}–$3 \cdot 10^{-7}$	99.5% / 10^{-6}–$3 \cdot 10^{-6}$	99.94–99.95% / 10^{-7}	99.3–99.4% / 10^{-6}–$3 \cdot 10^{-6}$	99.94–100% / $\leq 10^{-7}$
PQ	99.995–99.997% / 10^{-7}	100% / none	99.995–99.997% / 10^{-7}	100% / none	100% / none
Binary	99.991% / 10^{-7}–$3 \cdot 10^{-7}$	99.94% / 10^{-7}	99.991% / 10^{-7}	99.94% / 10^{-7}	100% / none
Max. abs. coordinate difference	$4.3 \cdot 10^{-7}$	$1.0 \cdot 10^{-5}$	$3.6 \cdot 10^{-7}$	$5.6 \cdot 10^{-6}$	$1.9 \cdot 10^{-7}$

equality fails rarely, and the smallest tested width that accepted every honest vector was the same on the desktop (NVIDIA GPU and x86 CPU) and on the Apple M2 (Metal GPU and ARM CPU): $3 \cdot 10^{-7}$ for MiniLM and $3 \cdot 10^{-6}$ for BGE-M3 with SQ8, and at most $3 \cdot 10^{-7}$, or none, for binary and PQ codes. For SQ and binary codes, whose guard widths are in value units, it was in every setting at or below the largest observed cross-device float deviation ($4.3 \cdot 10^{-7}$ and $1.0 \cdot 10^{-5}$ on the desktop, $3.6 \cdot 10^{-7}$ and $5.6 \cdot 10^{-6}$ on the M2). Guard exceptions are rare: on the Apple M2, at the smallest sufficient width, 0.9% of MiniLM and 9% of BGE-M3 SQ8 vectors relied on one to three exceptions. These widths are empirical calibrations on our samples and a grid of tested values, not guarantees for other data; a deployment should measure the deviation between its own publisher and verifier platforms.

The Apple M2 replication used the same corpus and the pinned model revisions; the x86–ARM comparison uses the windows embedded on the desktop and on the Pi (PyTorch on the GPU gives the same picture: largest deviation $2.6 \cdot 10^{-7}$, all vectors accepted at 10^{-7}). The formats that make tolerance-based audits useless are thus the ones that make code-level audits most portable: coarse cells absorb float noise.

Residual budget and canonicalisation. A compromised publisher could choose, at every ambiguous entry, the admissible code that raises a carrier and lowers the gold. We measured this on SQuAD with ambiguity decided by the verifier: at the calibrated widths, the publisher's choice hijacks no query for MiniLM (SQ8, SQ4 or PQ) and at most 0.16% for BGE-M3 (SQ8 at $3 \cdot 10^{-6}$); with a needlessly wide band of 10^{-5} it reaches 0.41%, against 2–100% for tolerance-based audits. The residual disappears if the verifier *canonicalises*: it accepts ambiguous entries but replaces them with its own codes, so the publisher has no choice left.

5.4 RQ4a: Cost of Verification on the Device's CPU

Re-embedding the 1,745-window corpus on the Raspberry Pi takes 72.9 s in FP32 and 41.6 s in dynamic INT8 with four CPU cores (for reference, the earlier study's BGE-M3 indexing of the 950 passages on the CPU took 1,725 s). Running the embedding model on the CPU next to the language model is expensive (Table 6): verifying 8 text–vector pairs per second costs the model 23–31% of its decoding speed and raises the 99th-percentile inter-token latency by 108–167%, and re-indexing at full speed costs 64–74%. Verification

Table 6 Local LLM decoding on the Raspberry Pi 5 with an INT8 encoder (ONNX Runtime, 1–4 threads) running concurrently on the CPU: range over thread counts, three full runs (reference: 5.14 tokens/s, p99 inter-token latency 210 ms)

Encoder load	Effect on the language model
Saturating (re-indexing, 15–25 items/s)	decode -64.5% to -73.9%
Periodic verification, 8 pairs/s	decode -22.9% to -31.4%, p99 $+108\%$ to $+167\%$

on the device's CPU is therefore feasible but competes with generation; it is best scheduled when the model is idle or moved to a separate processor.

5.5 RQ4b: End to End on the Device

Attack. We built attacked contexts for the 100 answerable questions by adding one chunk with a fixed, instruction-bearing editorial note (stating that the requested information is not available in the collection), whose text is the same in every condition (the exact text and the construction are in the released code), and shipping, within each verifier's tolerance, a vector that places it in the top-3 context; we then ran the device's LLM. Without attack, the model answers 0.75 correctly and refuses 0.13. With an FP32 verifier at $\tau = 0.999$, they are 0.74 and 0.13. Unlike the margin-law attacker, which rotates the closest competing passage, this attack must bring one fixed, off-topic instruction chunk into the context; a rotation of 2.6° is not enough for that, whereas the INT8 reference threshold (25.3°) is. With that threshold, correct answers fall to 0.39 and refusals rise to 0.50 (wrong answers 0.11). Delivery and effect separate cleanly: the payload entered the top-3 context for 100% of questions without a vector check, 2% at $\tau = 0.999$ and 94% at the INT8 reference threshold, and in every condition the shipped vector stayed within the angular budget and the same 100 questions were used.

Pack updates. We built 19 update cases (12 structural attacks, three legitimate updates, three content-level attacks and one vector desynchronisation), verified on the device with FP32 vector checks; 17 of 19 decisions matched the expected outcome. Layered verification (signature, hashes, sequence and parent, declared change set, editor threshold for supersede and delete, revocation, transparency log) rejected all 12 structural attacks. The two mismatches concern content-level screening, which quarantines an added chunk when its maximum NLI contradiction probability against the nearest existing sentences reaches $\theta = 0.5$: a benign addition was quarantined, and a poisoned addition that does not overlap existing content was not handled as expected (Sect. 5.6). A naive vector desynchronisation (vectors far from their text) was quarantined; a tolerance-aware attacker, as shown above, passes a check at INT8-level tolerance.

5.6 Negative Results

Abstention. Relevance scores do not separate in-topic unanswerable from answerable questions on SQuAD (AUROC 0.69 bi-encoder, 0.63 cross-encoder), whereas an extractive-QA no-answer margin does (0.86). On MS MARCO the ranking reverses (bi-encoder 0.76, cross-encoder 0.83, QA margin 0.70): the QA margin, whose model was trained on SQuAD, is best on SQuAD, and the cross-encoder, trained on MS MARCO, is best on MS MARCO. The ranking of the scorers reversed between datasets, so no scorer can be assumed to transfer, and gates must be calibrated in domain.

Context pruning. Keeping the three best sentences cut latency 2.9-fold (8.6 s versus 25.1 s) but correct answers fell from 0.75 to 0.44, although the answer string was present in 96% of pruned contexts. Wrong answers on answerable questions barely changed (0.13 versus 0.12); instead the model abstained more on them (0.43 versus 0.13), and more often on in-topic unanswerable questions (0.80 versus 0.66), with out-of-corpus questions refused in both (0.99). Adding neighbouring sentences reduced abstention (0.30) but doubled wrong answers (0.25). The pre-registered non-inferiority criterion (a margin of 5 percentage points) is not met.

Semantic screening of updates. An NLI screen for silent factual overrides failed (AUROC 0.18): the tested NLI model judges a near-copy with a changed fact as entailed, consistent with a known lexical-overlap bias [37, 15]. An exploratory near-duplicate-edit signal reached 0.998 but is defeated by full paraphrases.

6 Discussion

6.1 Why Tolerance Fails: the Geometry of Retrieval Margins

The central observation of this study is a mismatch of scales. Retrieval decisions in our corpora are taken by small angular differences: the median margin between the gold unit and its closest competitor is 2.1–7.4° across five corpora and two embedding models, and for 5% of SQuAD queries it is below 0.6° (BGE-M3). The deviations that real pipelines introduce between a publisher's vector and a verifier's recomputation fall into three regimes that relate very differently to these margins.

Floating-point noise. Recomputing the same model in FP32 on another device changes vector coordinates by 10^{-7}–10^{-5} (maximum absolute coordinate difference); the largest angular deviation we measured, between x86 and ARM, was 0.04°. This is far below typical margins, but not below all of them: queries whose closest competitor is a near-duplicate of the gold document have margins of the same order, which is why a tolerance at the level of cross-architecture noise still leaves up to 5.5% of queries exposed (idealised margin-law exposure) (0% in SciFact, most in ArguAna and NFCorpus), most of them because the corpus contains exact duplicates of the gold document, and up to 1.2% otherwise. Exposure at this level is therefore a property of the corpus as much as of the tolerance, and its harm must be judged per query.

Quantised computation. INT8 inference changes vectors by tens of degrees (median INT8–FP32 cosine 0.956 for all-MiniLM-L6-v2 in ONNX Runtime; the 0.1% quantile, our reference threshold, corresponds to 25.3°). A threshold that accepts nearly all honest INT8 vectors is wider than almost every margin, and the margin law then predicts that 98–100% of queries can be hijacked. An attacker who does not know the exact wording of the user's question, but knows the target passage and other questions about it, succeeds for 44–81% of SQuAD queries.

Compressed storage. Vector databases that store SQ, PQ or binary codes introduce reconstruction errors from a fraction of a degree (SQ8) to tens of degrees (PQ, binary). An audit that compares stored vectors with recomputed ones must tolerate these errors to avoid false alarms on honest data, and inherits the corresponding attack budget: 2–15% for SQ8, 55–89% for SQ4 and essentially all queries for PQ and binary codes. On real FAISS indexes the same pattern appears (8.3% for SQ8, 100% for PQ and binary), and an executed attack on a product-quantisation index placed the attacker's document first for a quarter of the targets with tampered vectors that all passed the check.

The practical consequence is that the safety of a tolerance cannot be judged in the abstract. It depends on the corpus, the embedding model and the storage format, and it can be measured. The margin law turns this measurement into a routine computation over honest vectors and a query log, without running any attack. The end-to-end experiment shows that the harm is concrete: on the device, an attack that stays within the INT8 reference threshold lowered correct answers from 0.75 to 0.39 and raised refusals from 0.13 to 0.50, by placing in the context an editorial note assumed to have passed content review.

6.2 Choosing a Verification Strategy

Table 7 compares the verification strategies we studied by what they guarantee, what they leave exposed in our measurements, what they require, and what they cost. Three observations follow.

First, the strongest guarantees come from removing the publisher's vectors from the trust base altogether, either by recomputing and discarding them on the device or by canonicalising stored codes. In both cases the verifier's own computation decides retrieval, and the publisher's choices of shipped vectors or codes have no effect on it. Second, exact equality is attractive because it needs no calibration, but it moves the trust problem to the reproducibility of the agreed computation: publisher and device must run a computation shown to be bit-reproducible, which none of the floating-point or dynamic-INT8 pipelines we measured is. Third, tolerance-based recomputation (V2) is the weakest option that still costs a full embedding pass; it only makes sense when its exposure, measured with the margin law on the deployment's own corpus, is acceptable.

A natural question is why a verifier that already recomputes embeddings should check the stored codes at all, rather than simply replace them. Replacement alone gives the same retrieval result, but it is silent: a store rewritten with tampered codes would be repaired without anyone learning that a writer had tampered

Table 7 Verification strategies for shipped or stored vectors: guarantee, residual exposure measured in this study, requirements and cost

Strategy	Guarantee and residual exposure	Requirements	Cost
Signature only (V1)	Provenance of the bytes; no text–vector binding. A compromised signer controls retrieval.	Key management, transparency log	Negligible
Recompute and accept within τ (V2)	Exposure equals the margin law at $\arccos\tau$: 0–5.5% at FP32 noise, 17–25% at $\tau = 0.999$ (SQuAD), 98–100% at the MiniLM CPU-INT8 reference threshold	Same model and pre-processing as the publisher	One embedding per chunk
Recompute and discard	No exposure from shipped vectors: the device retrieves with its own vectors	A device-side embedder; the publisher's numerics become irrelevant	Full re-embedding (72.9 s in FP32, 41.6 s in INT8 for 1,745 windows on the Raspberry Pi CPU)
Exact equality with a bit-reproducible computation (V3)	No exposure	A computation shown to be bit-reproducible at publisher and device (for example identical hardware and software, or integer-only inference)	One embedding per chunk
Code-level verification without canonicalisation (V4 without its last step)	At calibrated guard widths, 0% (MiniLM) to 0.16% (BGE-M3, SQ8)	Trusted codebook and embedding configuration; calibrated guard width per platform pair	Re-embedding plus quantisation
Code-level verification with canonicalisation (V4)	No residual exposure by construction; all honest vectors accepted in our samples	As above	As above

with it. Verification before canonicalisation turns the inconsistency into an event: the pack or the writer can be rejected, the discrepancy logged, and update policy applied. The guarantee against steering comes from canonicalisation; the detection of out-of-policy inconsistencies, their logging and the policy come from the check, while attributing them to a party relies on the signatures. Both are bounded by the same assumptions: a trusted codebook and embedding configuration, a correct binding between document identifiers, text and codes, and protection of the store after the audit. Within those assumptions the publisher has no residual choice; outside them, for instance through the index structure, other controls are needed (Sect. 6.4).

The cost of the stronger options is the cost of embedding. On the Raspberry Pi CPU, the full corpus is re-embedded in about a minute, and verification at 8 pairs per second alongside generation costs the language model 23–31% of its decoding speed; a separate accelerator could reduce this cost, which we leave to future work. On larger hardware it is modest; for orientation, recomputing all-MiniLM-L6-v2 embeddings for the 57,638 FiQA documents took 277 s on the Apple M2 CPU and 106 s on its GPU, and BGE-M3 embeddings for 5,000 documents took 966 s and 462 s. Code-level verification can therefore run as a periodic or ingestion-time audit rather than on the query path.

6.3 Design Guidelines

We distil the results into recommendations for builders of offline RAG systems and vector stores.

1. **Do not treat a signature as a binding between text and vectors.** Signatures establish who published a pack; they do not show that its vectors encode its text. A compromised or malicious signer is exactly the case the binding must cover.

2. **Measure before choosing a tolerance.** Any verification tolerance is an attack budget. Compute the margin distribution of the deployment's corpus and model on representative queries and read the

exposure off the margin law; pay attention to near-duplicates, which create exposure even at float-noise tolerances.

3. **Prefer recompute-and-discard on devices that can afford it.** If the device embeds the content itself and retrieves with its own vectors, the shipped vectors play no role in retrieval. On a small board the cost is about a minute per corpus of this size on the CPU.

4. **Audit compressed stores at the level of codes, and canonicalise.** Decide ambiguity from the verifier's own recomputation, accept a neighbouring code only where the verifier sees ambiguity, and replace accepted ambiguous entries with the verifier's codes. Calibrate the guard width from the measured float deviation between the actual publisher and verifier platforms, and recalibrate after any change of model, runtime or hardware.

5. **Bind the codebook and the configuration.** Code-level verification is only as trustworthy as the codebook and the embedding configuration it uses. Their hashes, together with the model revision, tokeniser, truncation length, pooling and normalisation, belong in the signed manifest; a verifier should never accept a codebook from the same party whose codes it verifies.

6. **Pin everything that affects numerics.** Model revisions, runtime and compiler versions and compiled accelerator graphs should be pinned and recorded, so that a verifier can reproduce the publisher's computation and an auditor can reproduce the verifier's.

7. **Require a demonstrably bit-reproducible computation for exact verification** at publisher and device.

8. **Schedule verification away from the language model's compute.** On the CPU of an edge device, verification at a modest rate slows decoding by roughly a quarter to a third; schedule it when the model is idle or move it to a separate processor.

9. **Calibrate abstention in domain and evaluate context pruning by its error decomposition**, not by accuracy alone.

6.4 Implications for Vector Databases and Integrity Guidance

Current guidance for LLM applications recommends regularly auditing and validating the integrity of the knowledge base and accepting data only from trusted sources [17], and per-embedding signatures have been proposed to make tampering after embedding detectable [18]. Our results add two points. Provenance controls do not cover a compromised writer, who can sign or store whatever vectors it wants; and integrity audits that compare stored vectors with recomputed ones are ineffective for compressed formats that many production stores use. Code-level verification gives the recommended audit a concrete, measurable form that works for those formats, and it complements provenance: signatures tell the verifier who wrote a code, recomputation tells it whether the code is consistent with the text.

Code-level verification fits naturally into three points of a vector database's life cycle: at ingestion, where a writer's codes can be checked against an independent recomputation before they become searchable; at replication or synchronisation between sites, where a replica can verify the codes it receives; and in periodic background audits, which can be scheduled at low priority because the cost is that of re-embedding. Canonicalisation means that an audit does not merely detect inconsistency but repairs the ambiguous entries; in our samples and at the guard widths we tested, it rejected no honest vector.

Our FAISS experiments used flat indexes. Production systems often add a coarse quantiser (IVF) or a proximity graph (HNSW) on top of compressed codes. A coarse-quantiser assignment is itself a code and can be verified the same way; graph edges are not determined by the text alone and their integrity requires different mechanisms. We leave these structures to future work.

6.5 Implications for Edge Devices

Two properties of edge inference matter for trust mechanisms. First, determinism becomes a security property: exact verification is possible only if inference is bit-reproducible, and none of the pipelines we measured is (PyTorch on NVIDIA and Apple GPUs and on CPUs varied with batch size, ONNX Runtime FP32 varied across architectures, and dynamic INT8 varied with the other inputs in the batch). Stacks that are bit-reproducible by construction, such as integer-only inference [22, 23] or pinned kernels on fixed hardware [21], are therefore the natural basis for exact verification at the edge. Second, cost: on the device's CPU, verification competes directly with the language model for compute. Dedicated accelerators may change both properties; measuring their determinism and their cost next to a running model is an important next step.

6.6 Lessons from the Negative Results

Three pre-registered expectations failed, and each carries a lesson for trust mechanisms in offline RAG. Relevance scores did not identify in-topic unanswerable questions, and the ranking of the abstention scorers reversed between SQuAD and MS MARCO, so none can be assumed to transfer. An offline device that must abstain safely therefore needs abstention thresholds calibrated on its own domain, which in a disconnected setting means shipping calibration data or thresholds with the knowledge pack. Context pruning reduced latency nearly threefold with almost no change in wrong answers, but it converted correct answers into abstentions; whether that trade is acceptable depends on the relative cost of a wrong answer and an abstention, and can only be judged from the full error decomposition. Finally, a small NLI model was not able to detect silent factual overrides, because it judges a near-copy with a changed fact as consistent. Structural governance, i.e. editor thresholds for changes to existing content, rejected all twelve structural attacks we tested and remains the reliable control for updates; semantic screening is at best a secondary signal.

6.7 Threats to Validity

Internal validity. All code-level results were produced by a single reference verifier whose rules match the description in Sect. 5.3 and that is covered by unit tests. During the study, an earlier measurement that decided ambiguity from the publisher's vectors was superseded, and a first run of the reference verifier on one platform produced inconsistent counters that disappeared after a fix for constant dimensions and a change of numerical library version; only the corrected runs are reported, and both events are recorded in the protocol. Latencies of the language model are reported without prompt-cache hits, which we detected and removed.

Construct validity. We measure hijacking as displacement of the gold unit from rank 1 (in the FAISS experiment, as the attacker's document ranking first under the index's scoring, the honest ranking being taken from the uncompressed vectors) and payload delivery as entry into the top-3 context; other definitions of harm are possible. The margin law describes an optimal attacker that rotates one competing vector; an attacker who can also move the gold vector has a larger budget, so our figures are conservative in that respect. Tolerances were set from honest data (the 0.1% quantile of honest INT8 cosines, the largest honest reconstruction angle of a store); a deployment that accepts occasional false alarms could use tighter values, at the price of rejecting honest content. The executed FAISS attack is greedy and restricted to the codebook and is therefore a lower bound.

External validity. We studied two embedding models, English corpora of up to 57,638 documents, flat FAISS indexes, one board with inference on its CPU, and one local language model. The CPU-INT8 reference threshold was measured for one model with one runtime and dynamic quantisation, whose outputs depend on the batch; other quantisation schemes and accelerators will have other tolerances, which the margin law turns into exposure. Guard widths are empirical calibrations from three platforms and a grid of tested values, not guarantees for other models or hardware. The update scenarios are synthetic.

Statistical conclusion validity. Where confidence intervals are given for proportions they are Wilson intervals, the main systems result is the mean of three full runs with narrow ranges, and the end-to-end experiment uses 100 questions per condition. Exploratory analyses are labelled as such and logged with dates in the protocol.

6.8 Ethics and Responsible Disclosure

The attacks studied here require write access to a knowledge pack or a vector store; they model compromised publishers, build pipelines and insiders rather than remote attackers. We present every attack together with a method to measure exposure and with defences, and we release the measurement tools so that operators can assess their own systems.

6.9 Future Work

Several directions follow directly from the limitations above: measuring the determinism and cost of verification on edge accelerators; extending code-level verification to IVF and graph-based indexes and to multilingual corpora at larger scale; studying attackers who modify both text and vectors; deriving guard widths from a model of floating-point error rather than from measurement alone; and specifying a canonical, signed representation of embedding configurations and codebooks that verifiers in different systems could share.

7 Conclusion

Offline retrieval-augmented generation depends on knowledge that arrives in packs, and packs carry vectors as well as text. A signature tells a device who published those vectors; it does not tell it whether they encode the text. We showed that any check which tries to establish that binding within a tolerance concedes a predictable share of queries to an attacker who controls the vectors, and that this share is given by the distribution of retrieval margins. Margins are small in every corpus we studied, so float-noise tolerances leave a measurable exposure, a threshold calibrated on INT8 inference leaves 98–100% of queries exposed, and integrity audits of compressed vector stores leave up to all queries exposed. On a real FAISS index, an attack whose tampered vectors all passed such an audit ranked the attacker's document first under the index's own scoring for a quarter of the targets; on the device, a comparable attack nearly halved the language model's correct answers (from 0.75 to 0.39).

The gap can be closed. Recomputing vectors on the device and discarding the shipped ones removes the publisher's influence through the shipped vectors; exact verification removes it as well, provided that publisher and device share a bit-reproducible stack; and for compressed stores, verifying quantisation codes, with ambiguity decided by the verifier, a calibrated guard band and canonicalisation, accepted every honest vector in our samples on three platforms and four compute backends while leaving no choice to the publisher. On the CPU of a small board, the necessary recomputation is affordable but competes with the language model, which makes scheduling, or a separate processor, part of the design.

These results turn a recommendation that knowledge bases should be checked for integrity into a procedure that can be measured, calibrated and audited. We release the code, the data, the reference verifier and the protocol with its deviation log, so that operators can measure the exposure of their own systems and adopt the defences.

Statements and Declarations

Use of AI tools. The authors used standard writing and production tools (Grammarly, Overleaf) for language editing and LaTeX preparation. Generative AI assistants were used to help identify candidate literature, to cross-check bibliographic metadata, and to help write the experiment and analysis scripts; every reference was verified by the authors against the publisher, DOI, or preprint-server record, and all code and results were reviewed by the authors. The AI tools did not generate the framework, the findings, or the conclusions. The authors take full responsibility for the manuscript.

Funding. This work was funded by securagen.ai.

Competing interests. The authors are affiliated with securagen.ai P.C., which develops commercial software in the areas discussed in this paper. The experiments used open-source software and publicly available model

weights under their respective licences. The authors have no other relevant financial or non-financial interests to disclose.

Ethics approval and consent to participate. Not applicable.

Consent for publication. Not applicable.

Data availability. Per-query results, vectors where licences permit, system information and analysis outputs are available at `https://github.com/securagenai/signed-but-steerable` (archived release v1.0.2: doi:10.5281/zenodo.23948839). SQuAD 2.0, BEIR and MS MARCO are publicly available [14, 35, 36].

Code availability. All scripts, the pre-registered protocol with its deviation log, and the pinned versions of models and tools are available at `https://github.com/securagenai/signed-but-steerable` (archived release v1.0.2: doi:10.5281/zenodo.23948839). The implementation uses open-source software (llama.cpp, ONNX Runtime, sentence-transformers, FAISS). The generated answers released with the code were produced with Qwen2.5-3B-Instruct, used for research under the Qwen Research License; the embedding, reranking, NLI and QA models are used under their respective licences, and SQuAD 2.0, BEIR and MS MARCO under their terms of use. Raspberry Pi is a trademark of Raspberry Pi Ltd; other product names are trademarks of their respective owners.

Author contribution. Georgios Feretzakis and Alexandros Papaspyridis had the idea for the article. Georgios Feretzakis designed the methodology, designed and conducted the experiments, analysed the results, wrote the manuscript, and supervised and administered the project. Alexandros Papaspyridis critically revised the work. Both authors read and approved the final manuscript.

References

[1] Gerganov G et al (2026) llama.cpp: LLM inference in C/C++. `https://github.com/ggml-org/llama.cpp`, commit 098ce526b546b5a190327c1da82929cee051b9ac. Accessed 19 October 2026

[2] Lewis P, Perez E, Piktus A, Petroni F, Karpukhin V, Goyal N, Küttler H, Lewis M, Yih W-t, Rocktäschel T et al (2020) Retrieval-augmented generation for knowledge-intensive NLP tasks. In: Advances in Neural Information Processing Systems (NeurIPS) 33, Virtual, 6–12 December 2020, pp 9459–9474

[3] Seemakhupt K, Liu S, Khan S (2024) EdgeRAG: online-indexed RAG for edge devices. arXiv:2412.21023

[4] Kamath A, Jia R, Liang P (2020) Selective question answering under domain shift. In: Proceedings of the 58th Annual Meeting of the Association for Computational Linguistics (ACL), Virtual, 5–10 July 2020, pp 5684–5696. `https://doi.org/10.18653/v1/2020.acl-main.503`

[5] Peng X, Choubey PK, Xiong C, Wu C-S (2025) Unanswerability evaluation for retrieval augmented generation. In: Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers), Vienna, Austria, pp 8452–8472. `https://doi.org/10.18653/v1/2025.acl-long.415`

[6] Chen J, Xiao S, Zhang P, Luo K, Lian D, Liu Z (2024) M3-Embedding: multi-linguality, multi-functionality, multi-granularity text embeddings through self-knowledge distillation. In: Findings of the Association for Computational Linguistics: ACL 2024, Bangkok, Thailand, 11–16 August 2024, pp 2318–2335. `https://doi.org/10.18653/v1/2024.findings-acl.137`

[7] Malkov YA, Yashunin DA (2020) Efficient and robust approximate nearest neighbor search using hierarchical navigable small world graphs. IEEE Trans Pattern Anal Mach Intell 42(4):824–836. `https://doi.org/10.1109/TPAMI.2018.2889473`

[8] Zou W, Geng R, Wang B, Jia J (2025) PoisonedRAG: knowledge corruption attacks to retrieval-augmented generation of large language models. In: Proceedings of the 34th USENIX Security Symposium, Seattle, WA, USA, 13–15 August 2025, pp 3827–3844

[9] Xiang C, Wu T, Zhong Z, Wagner D, Chen D, Mittal P (2024) Certifiably robust RAG against retrieval corruption. arXiv:2405.15556

[10] Maruseac M, Wickens E, Major D, Sablotny M (2025) An introduction to the OpenSSF Model Signing (OMS) specification: model signing for secure and trusted AI supply chains. OpenSSF Blog, 25 June 2025. https://openssf.org/blog/2025/06/25/an-introduction-to-the-openssf-model-signing-oms-specification/; specification: https://github.com/ossf/model-signing-spec. Accessed 20 October 2026

[11] Samuel J, Mathewson N, Cappos J, Dingledine R (2010) Survivable key compromise in software update systems. In: Proceedings of the 17th ACM Conference on Computer and Communications Security (CCS), Chicago, IL, USA, pp 61–72. https://doi.org/10.1145/1866307.1866315

[12] Moran B, Tschofenig H, Birkholz H (2022) A manifest information model for firmware updates in Internet of Things (IoT) devices. RFC 9124, Internet Engineering Task Force. https://www.rfc-editor.org/rfc/rfc9124

[13] Yang A, Yang B, Zhang B, Hui B, Zheng B, Yu B, Li C, Liu D, Huang F, Wei H et al (2024) Qwen2.5 technical report. arXiv:2412.15115

[14] Rajpurkar P, Jia R, Liang P (2018) Know what you don't know: unanswerable questions for SQuAD. In: Proceedings of the 56th Annual Meeting of the Association for Computational Linguistics (ACL) (Volume 2: Short Papers), Melbourne, Australia, 15–20 July 2018, pp 784–789. https://doi.org/10.18653/v1/P18-2124

[15] Chen J, Choi E, Durrett G (2021) Can NLI models verify QA systems' predictions? In: Findings of the Association for Computational Linguistics: EMNLP 2021, Punta Cana, Dominican Republic, pp 3841–3854. https://doi.org/10.18653/v1/2021.findings-emnlp.324

[16] Feretzakis G, Papaspyridis A (2026) Trust mechanisms for offline generative AI at the edge: a connectivity-regime framework and an empirical study on a Raspberry Pi 5. arXiv:2610.33732

[17] OWASP GenAI Security Project (2024) LLM08:2025 Vector and embedding weaknesses. In: OWASP Top 10 for LLM Applications 2025. https://genai.owasp.org/llmrisk/llm082025-vector-and-embedding-weaknesses/. Accessed 1 November 2026

[18] Wanger J (2026) VectorSmuggle: steganographic exfiltration in embedding stores and a cryptographic provenance defense. arXiv:2605.13764

[19] He H, Thinking Machines Lab (2025) Defeating nondeterminism in LLM inference. Thinking Machines Lab: Connectionism, September 2025. https://thinkingmachines.ai/blog/defeating-nondeterminism-in-llm-inference/. Accessed 1 November 2026

[20] Foerster H, Shumailov I, Zhang C, Zhao Y, Hayes J, Mullins R (2026) Quantamination: dynamic quantization leaks your data across the batch. arXiv:2604.26505

[21] Ribeiro Alves D, Patankar V, Pereira M, Stephens J, Vaziri N, Kannan S (2026) EigenAI: deterministic inference, verifiable results. arXiv:2602.00182

[22] Barry N (2026) Eliminating nondeterminism in LLM inference via integer-only arithmetic. In: NeurIPS 2026 Workshop on On-Device Intelligence: Foundation Models under Real-World Constraints. https://openreview.net/forum?id=yCJPh9NkW1

[23] Mićić N (2026) int-llm: integer-only LLM stack in pure C. https://github.com/nmicic/int-llm. Accessed 1 November 2026

[24] Jacob B, Kligys S, Chen B, Zhu M, Tang M, Howard A, Adam H, Kalenichenko D (2018) Quantization and training of neural networks for efficient integer-arithmetic-only inference. In: Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR), Salt Lake City, UT, USA, pp 2704–2713

[25] Kim S, Gholami A, Yao Z, Mahoney MW, Keutzer K (2021) I-BERT: integer-only BERT quantization. In: Proceedings of the 38th International Conference on Machine Learning (ICML), Virtual; PMLR 139, pp 5506–5518

[26] Ong JM, Di Ferrante M, Pazdera A, Garner R, Jaghouar S, Basra M, Ryabinin M, Hagemann J (2025) TOPLOC: a locality sensitive hashing scheme for trustless verifiable inference. arXiv:2501.16007

[27] Egashira K, Vero M, Staab R, He J, Vechev M (2024) Exploiting LLM quantization. In: Advances in Neural Information Processing Systems (NeurIPS) 37, Vancouver, Canada

[28] Jégou H, Douze M, Schmid C (2011) Product quantization for nearest neighbor search. IEEE Trans Pattern Anal Mach Intell 33(1):117–128

[29] Douze M, Guzhva A, Deng C, Johnson J, Szilvasy G, Mazaré P-E, Lomeli M, Hosseini L, Jégou H (2024) The Faiss library. arXiv:2401.08281

[30] Laurie B, Langley A, Kasper E (2013) Certificate Transparency. RFC 6962, Internet Engineering Task Force. `https://www.rfc-editor.org/rfc/rfc6962`

[31] Newman Z, Meyers JS, Torres-Arias S (2022) Sigstore: software signing for everybody. In: Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security (CCS), Los Angeles, CA, USA, pp 2353–2367

[32] Reimers N, Gurevych I (2019) Sentence-BERT: sentence embeddings using Siamese BERT-networks. In: Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP), Hong Kong, China, pp 3982–3992

[33] Wang W, Wei F, Dong L, Bao H, Yang N, Zhou M (2020) MiniLM: deep self-attention distillation for task-agnostic compression of pre-trained transformers. In: Advances in Neural Information Processing Systems (NeurIPS) 33, Virtual, pp 5776–5788

[34] Hugging Face (2026) Model cards: `sentence-transformers/all-MiniLM-L6-v2`, `cross-encoder/ms-marco-MiniLM-L-6-v2`, `cross-encoder/nli-MiniLM2-L6-H768`, `deepset/minilm-uncased-squad2`. `https://huggingface.co`. Accessed 1 November 2026. Exact identifiers and revisions: `pins.json` in the archived release, `https://doi.org/10.5281/zenodo.23948839`

[35] Thakur N, Reimers N, Rücklé A, Srivastava A, Gurevych I (2021) BEIR: a heterogeneous benchmark for zero-shot evaluation of information retrieval models. In: Proceedings of the Neural Information Processing Systems Track on Datasets and Benchmarks 1, Virtual

[36] Bajaj P, Campos D, Craswell N, Deng L, Gao J, Liu X, Majumder R, McNamara A, Mitra B, Nguyen T et al (2016) MS MARCO: a human generated machine reading comprehension dataset. arXiv:1611.09268

[37] McCoy RT, Pavlick E, Linzen T (2019) Right for the wrong reasons: diagnosing syntactic heuristics in natural language inference. In: Proceedings of the 57th Annual Meeting of the Association for Computational Linguistics (ACL), Florence, Italy, pp 3428–3448

[38] Zhong Z, Huang Z, Wettig A, Chen D (2023) Poisoning retrieval corpora by injecting adversarial passages. In: Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP), Singapore, pp 13764–13775

[39] Greshake K, Abdelnabi S, Mishra S, Endres C, Holz T, Fritz M (2023) Not what you've signed up for: compromising real-world LLM-integrated applications with indirect prompt injection. In: Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec), Copenhagen, Denmark, pp 79–90

[40] Song C, Raghunathan A (2020) Information leakage in embedding models. In: Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security (CCS), Virtual, pp 377–390

[41] Morris JX, Kuleshov V, Shmatikov V, Rush AM (2023) Text embeddings reveal (almost) as much as text. In: Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP), Singapore, pp 12448–12460

[42] Goldberg D (1991) What every computer scientist should know about floating-point arithmetic. ACM Comput Surv 23(1):5–48

[43] Gholami A, Kim S, Dong Z, Yao Z, Mahoney MW, Keutzer K (2021) A survey of quantization methods for efficient neural network inference. arXiv:2103.13630

[44] Guo R, Sun P, Lindgren E, Geng Q, Simcha D, Chern F, Kumar S (2020) Accelerating large-scale inference with anisotropic vector quantization. In: Proceedings of the 37th International Conference on Machine Learning (ICML), Virtual; PMLR 119, pp 3887–3896

[45] Johnson J, Douze M, Jégou H (2021) Billion-scale similarity search with GPUs. IEEE Trans Big Data 7(3):535–547

[46] Torres-Arias S, Afzali H, Kuppusamy TK, Curtmola R, Cappos J (2019) in-toto: providing farm-to-table guarantees for bits and bytes. In: Proceedings of the 28th USENIX Security Symposium, Santa Clara, CA, USA, pp 1393–1410